



Assignment 2.2: Secure Architecture Guide + Diagrams (G2 Package)

Group 2: Brian Che, O.Kingsley Ero, Joshua Remington, Mikalou Nikiema, Mohammad Ahmed,
and Shivam Patel

Shiley-Marcos School of Engineering (SMSE), University of San Diego

CYBR-516-01B: Cyber Engineering Research II

Professor Douglas Magedman

07/05/2026

		Secure Architecture Guide + Diagrams	Client	Design World	
			Doc #	DW0004	
Effective Date	07/05/26		Rev. #	Rev 1	

Table Of Contents

1. Architecture Review Summary.....3

2. Secure Target State Architecture Guide.....5

3. Required Diagram Set..... 12

4. Architecture Delta Summary..... 15

5. Conclusions..... 16

6. Approvals..... 16

Appendix..... 18

		Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26		

1. Architecture Review Summary

The Architecture Review Findings show that Design World's current AI architecture is a good starting point, but it still depends too much on trust between internal components. The current diagram includes a controlled entry path through VPN, SSO/MFA, and the Cloud WAF. These controls are useful because they validate users before they enter the environment. However, the main security concerns begin after authentication, when activity moves into the Business Subnet and the Orchestration and Execution layers. At that point, the user reaches the Ubuntu workstation, and the orchestrator begins interacting with the platform. The diagram does not clearly show where user trust is reauthenticated or where unsafe AI activity would be detected.

The largest weakness is the lack of enforceable control points around the AI workflow. The Architecture Review Findings explain that the orchestrator can pass user input and RAG content to the local LLM. From there, the tool logic can trigger the shell tool, file tool, and email tool. This creates a high risk path. The design appears to assume that retrieved data, model output, and tool-generated results are safe enough to continue through the system. That assumption is not strong enough for an AI platform with access to sensitive internal data. A malicious file placed on the Windows File Server could be retrieved through RAG and lead to unauthorized actions by the AI platform. Those actions could include file writes, command execution, or send emails.

A second weakness is that privileged execution is not separated enough from normal AI processing. The current diagram places the tool execution host, shell tool, file tool, email tool, and service account activity in the same execution flow. This matters because the platform is not only generating answers for users. It is also positioned to act inside the environment. The Architecture Review Findings identified this issue which include tool privilege access and missing approval gates. The service account credentials shown in the diagram are especially important because they are used to access the Windows File Server and write artifacts. In the target-state design, that service account should be treated as a major control point.

The current design also does not show enough governance. The diagram includes status flows and tool results, but it does not show a protected logging layer, SIEM integration, approval record, or audit trail for prompts. The AI Systems & Security Requirements Report states that Design World's platform must support governance, auditability, traceability, and constrained execution. The platform is intended to support enterprise knowledge and controlled workflow assistance. These use cases require

		Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26		

evidence. Design World must be able to review all actions that were taken on the AI platform.

The target-state architecture is guided by several security design principles. The first is least privilege, which means users, tools, and service accounts should only receive the access needed for approved business workflows. The second is explicit trust boundaries. User access, RAG retrieval, LLM inference, tool execution, artifact storage, and response delivery should be treated as separate zones instead of one trusted internal process. Then we have enforceable control placement. Security checks should occur before sensitive data is retrieved, before RAG content reaches the LLM, and before any shell, file, or email tool is executed. Next is approved-tool governance, which limits tool use to authorized tools, approved actions, and defined business purposes. The last item is auditable AI activity. Prompts, retrieved sources, tool calls, approvals, outputs, and stored artifacts must be available for monitoring, compliance review, and executive readiness decisions.

The target-state architecture we will build must have all high-risk AI activity pass through a visible and enforceable control point. The redesign should not assume that internal traffic is safe. It should not assume that local model execution removes AI risk. It should also not assume that service account activity is trustworthy. Instead, the architecture should revalidate trust at each major stage. User access, retrieval, inference, execution, storage, and response delivery should each have controls that can be continuously monitored and logged.

For data retrieval, the architecture should enforce source validation, user permission checks, and data classification rules before information reaches the LLM. This directly addresses the RAG poisoning and indirect prompt injection risks identified in the Architecture Review Findings. The local vector database should only index approved data sources and preserve normal enterprise access rules. A user should not be able to retrieve restricted data through an AI prompt if that same user cannot access the data directly. This supports the AI Systems & Security Requirements Report requirement that AI retrieval, storage, processing, and output follow Design World's data governance and classification rules.

For tool execution, the architecture should include a policy enforcement point before any of the tools can run. The tool-calling logic should not execute an action only because the LLM recommends it. Each action should be checked against the user's role, the approved use case, the allowed tool list, the data classification involved, and the risk level of the requested action. High-risk actions require stronger control. This includes

		Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26		

shell execution and file modification. These actions should require approval where appropriate and complete logging in all cases. This keeps the platform aligned with the requirement that autonomous actions remain within the user's explicit permissions and do not bypass organizational oversight.

The target-state architecture should also reduce the risk created by broad service account access. In the current diagram, service account credentials are a central path for file access and artifact writing. In the redesigned architecture, those credentials should be scoped to specific approved actions and approved data locations. They should be limited by least privilege, monitored through centralized logging (SIEM integration), and reviewed on a regular basis. This changes the service account from a shared dependency into a governed control point.

Finally, protected audit logging must be part of the architecture itself. It should not be added later as a supporting feature. Design World should be able to trace the full AI activity trail from the original user request to the final output. This is what makes the target-state architecture efficient and ideal. The goal is not to add controls just to make the design look more secure. The goal is to correct the specific trust gaps shown in the current diagram by placing safeguards where applicable.

2. Secure Target State Architecture Guide

B.1 Purpose and Scope

The secure target-state architecture establishes a defensible AI platform that addresses the security, governance, and operational weaknesses identified during the Architecture Review Findings while preserving Design World's intended business functionality. Rather than replacing the current architecture, the redesigned solution strengthens the existing workflow by introducing explicit trust boundaries, enforceable security controls, and governance mechanisms that reduce AI-specific risk throughout the platform lifecycle.

The architecture is designed to support enterprise knowledge retrieval, document summarization, engineering assistance, and controlled workflow automation while ensuring that sensitive enterprise data remains protected. Every architectural decision supports Design World's business objectives while remaining practical enough to operate within the constraints established by the Statement of Work (SoW) and Project Change Request (PCR).

This architecture provides the baseline for the remaining threat modeling, assurance

		Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26		

planning, red-team evaluation, and executive readiness activities conducted throughout the engagement.

B.2 Design Assumptions and Constraints

The target-state architecture assumes Design World's AI platform will continue operating within the approved Akamai/Linode environment using the existing virtual infrastructure. Migration to another cloud provider is outside the scope of this engagement. Likewise, the architecture preserves the existing use of the local Ollama large language model, retrieval-augmented generation (RAG), and controlled agentic workflows while introducing additional security and governance capabilities around those components.

The redesign assumes that existing enterprise identity services—including VPN connectivity, single sign-on (SSO), multi-factor authentication (MFA), and Cloud Web Application Firewall (WAF) protections—remain operational and continue serving as the primary authentication boundary. Rather than replacing these controls, the architecture builds upon them through continuous validation as requests progress through the AI workflow.

Design World's governance requirements also establish several architectural constraints. Proprietary models will not be fine-tuned, unapproved AI tools are prohibited, and enterprise data must continue following existing classification and handling requirements regardless of whether it is accessed directly or through AI-assisted retrieval. These constraints ensure the architecture remains realistic while supporting recognized guidance such as the NIST AI RMF, OWASP LLM, MITRE ATLAS, and NIST SSDF.

B.3 Major Architectural Components

The target-state architecture preserves the current operational workflow while introducing additional security functions at the most critical decision points. The Identity and Edge Defense layer remains the primary entry point into the environment, providing VPN connectivity, SSO, MFA, and Cloud WAF protections before any AI interaction occurs. Together, these services establish the first explicit trust boundary by authenticating users and validating incoming requests before access is granted to enterprise resources.

Within the Business Subnet, authorized users continue accessing the AI platform through the Ubuntu workstation. Unlike the current-state architecture, however, requests must first pass through a dedicated Policy Enforcement Point (PEP). The PEP validates

		Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26		

user identity, approved business use cases, and applicable data classification requirements before requests are allowed to reach the AI orchestration layer.

The AI Orchestrator remains responsible for coordinating retrieval operations, inference requests, and communication between the Local Vector Database and the Ollama LLM. Before retrieval occurs, user prompts undergo validation to identify unauthorized or potentially malicious requests, including AI-specific misuse and prompt-manipulation attempts. The Retrieval-Augmented Generation (RAG) pipeline continues retrieving enterprise knowledge from approved data sources while preserving existing user permissions and organizational data classification requirements.

The Ollama LLM remains isolated from direct access to privileged enterprise resources. After inference is complete, generated responses pass through a dedicated output validation stage that evaluates policy compliance, data classification requirements, response integrity, and authorized disclosure before information progresses to tool execution or response delivery.

The Tool Execution layer remains the highest-risk portion of the architecture because it enables AI-generated actions to modify enterprise systems. Before shell commands, file operations, or email activities are executed, each request passes through a Tool Approval and Policy Gateway that verifies user authorization, approved business purpose, authorized tools, and applicable organizational policies.

Service accounts operate under least-privilege principles and are limited to the minimum permissions required for approved business operations. Finally, centralized logging and monitoring provide continuous visibility while supplying audit evidence necessary for governance, assurance activities, executive Go/No-Go decisions, and incident response.

B.4 Trust Boundaries (TB)

TB-1 – Identity and Edge Defense: The first trust boundary separates external users from Design World's enterprise environment. VPN connectivity, SSO, MFA, and Cloud WAF protections authenticate users and inspect requests before AI services become accessible.

TB-2 – AI Orchestration: Requests pass through the Policy Enforcement Point before retrieval operations or language model inference begin, validating user authorization, approved business use cases, and data classification requirements.

		Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26		

TB-3 – AI Inference and Tool Authorization: Generated responses are validated before any tool execution request is authorized, preventing AI-generated recommendations from automatically becoming privileged system actions.

TB-4 – Privileged Tool Execution: Shell commands, file operations, and email activities are individually authorized before interacting with enterprise resources, reducing the potential blast radius of compromised AI workflows.

TB-5 – Monitoring and Response Delivery: All AI activity is recorded before validated responses are returned to users, ensuring complete audit evidence across the workflow.

B.5 Control Enforcement

Security controls are distributed throughout the architecture so that risk is prevented as early as possible rather than detected after compromise. Identity verification occurs before access is granted to enterprise resources, while policy enforcement validates user authorization, approved business use cases, and applicable data classification requirements before AI processing begins.

Additional enforcement occurs throughout retrieval, inference, and tool execution. Prompt validation reduces AI-specific misuse before retrieval occurs, output validation confirms policy compliance and response integrity before responses continue through the workflow, and approval gates verify that privileged actions remain consistent with organizational governance.

B.6 Governance Integration

Governance is integrated directly into the architecture through policy enforcement, change management, and clearly defined ownership responsibilities. Approved AI models, enterprise tools, retrieval sources, and business use cases are governed through organizational policy rather than application logic alone. Changes affecting AI functionality require formal security review before implementation, ensuring governance remains enforceable throughout the platform lifecycle.

B.7 Logging, Monitoring, and Audit Evidence

The architecture records authentication events, prompt submissions, retrieval operations, model interactions, policy decisions, tool requests, privileged actions, service account activity, and final AI responses. Centralized monitoring enables Design World to investigate abnormal AI behavior, verify policy compliance, and demonstrate that

 Effective Date 07/05/26		Secure Architecture Guide + Diagrams	Client	Design World
			Doc #	DW0004
			Rev. #	Rev 1

organizational safeguards remain effective throughout platform operation.

These audit records provide the evidence required to support future assurance gates, executive Go/No-Go decisions, incident response activities, regulatory compliance reviews, architecture validation, and post-incident forensic investigations.

B.8 Traceability to Assignment 1.2 Requirements

The target-state architecture directly addresses the business, functional, security, governance, and architectural requirements established in document DW0001 Rev.1. Table B-1 summarizes how major architectural decisions trace directly to the approved requirements baseline.

Req. ID	Requirement	Architectural Response
SO-1	Data Confidentiality and Privacy Protection	The Policy Enforcement Point (PEP) validates data classification and user authorization before enterprise information is retrieved or passed to the LLM. The RAG pipeline preserves existing access controls so users cannot retrieve information beyond their authorized access level.
SO-2	Output Integrity and Trustworthiness	A dedicated output validation layer evaluates AI-generated responses for policy compliance, response integrity, authorized disclosure, and applicable data classification requirements before responses are delivered to users. Retrieval is limited to approved enterprise data sources to improve response reliability.

		Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26		

SO-3	Operational Resilience and System Availability	The architecture isolates the Tool Execution layer and limits service accounts to the minimum permissions required for approved business operations, reducing the potential impact of compromised workflows. Centralized monitoring provides visibility into platform availability, abnormal behavior, and operational health.
SO-4	Constrained Execution and Authorization Boundaries	The Tool Approval and Policy Gateway verifies every tool invocation against user permissions, approved business purpose, authorized tools, and organizational policy before execution. No AI-generated action proceeds without successfully passing these validation checks.
SO-5	Governance, Auditability, and Traceability	Centralized logging captures the complete AI activity chain, including authentication events, prompt submissions, retrieval operations, policy decisions, tool requests, privileged actions, and final responses. These records provide evidence for governance reviews, assurance activities, incident response, and executive Go/No-Go decisions.
SO-6	Alignment with Data Governance	The RAG pipeline enforces Design World's existing data classification and handling requirements. Information unavailable through normal enterprise access controls cannot be accessed through AI-assisted retrieval, ensuring AI workflows remain consistent with organizational governance policies.

		Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26		

UC-4	Controlled Workflow Assistance	The Tool Approval and Policy Gateway limits agentic actions to approved business purposes. Shell commands, file operations, and email activities are individually authorized before execution, preventing agents from operating outside approved tools or user permissions.
FE-4	Human Review and Decision Authority	The architecture requires approval records for high-impact agentic actions. AI-generated work products remain assistive outputs that require employee review and do not replace human decision-making for actions requiring professional judgment or organizational authority.
A-1	Hosting Limited to Akamai/Linode Environment	All architectural components remain within the approved Akamai/Linode infrastructure. The target-state architecture introduces security and governance improvements without changing the hosting environment defined in the Statement of Work and Project Change Request.
A-4	Engagement Remains Within Approved Project Scope	The redesign introduces no new cloud providers, unapproved AI tools, or proprietary model fine-tuning. All recommendations remain architectural improvements that comply with the existing Statement of Work (SoW) and Project Change Request (PCR).

		Client	Design World
		Doc #	DW0004
Effective Date	07/05/26	Rev. #	Rev 1

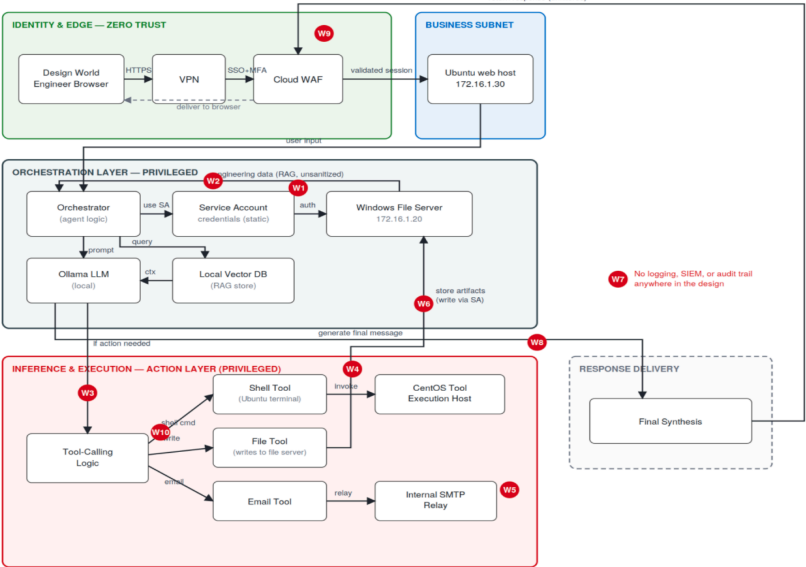
OQ-3	What Level of Residual AI Risk Is Acceptable Before Production Deployment?	The Tool Approval and Policy Gateway, centralized audit logging, and governance controls generate the evidence necessary to support executive Go/No-Go decisions. While the architecture cannot determine the organization's acceptable level of residual risk, it provides the information required for leadership to make an informed risk acceptance decision.
------	--	---

Traceability Note: All requirement identifiers reference document DW0001 Rev.1.
Requirements not addressed through the target-state architecture should be documented as residual gaps within the Architecture Delta Summary (Part D).

3. Required Diagram Set
- a. Current State Architecture with Weakness Annotations - The provided architecture with ten weakness markers (W1-W10): missing controls, trust issues, and governance gaps

Diagram 1 — Current-State Architecture (Structura AI) with Weakness Annotations

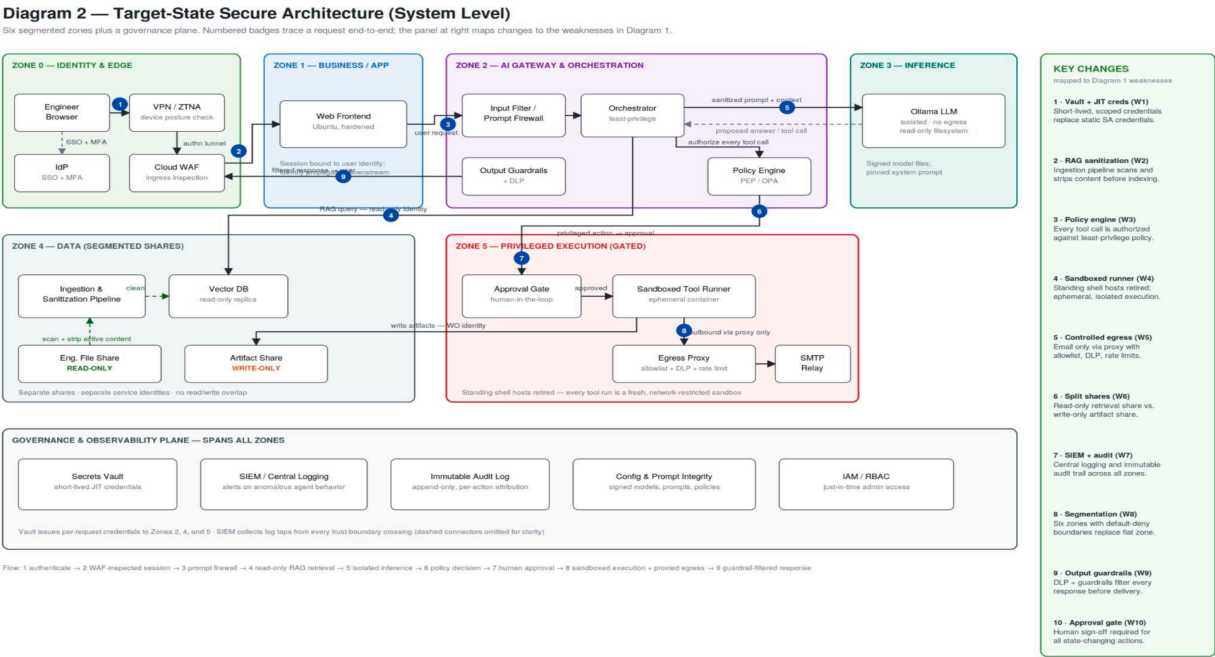
Red W-markers flag weaknesses, missing controls, trust issues, and governance concerns. Details in the panel at right.



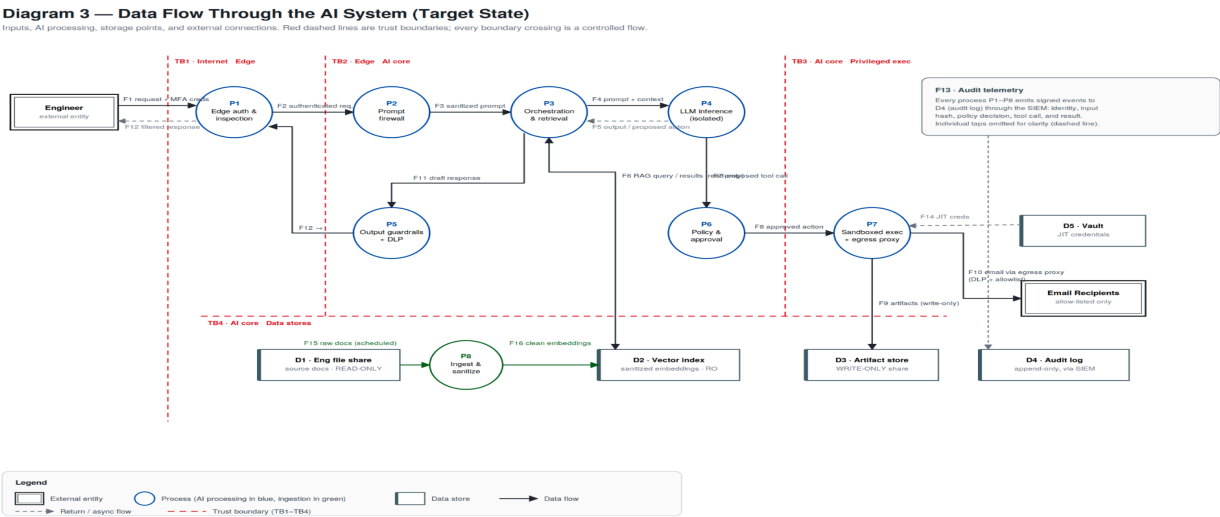
- IDENTIFIED WEAKNESSES**
- W1 Standing privileged credentials**
Static service-account creds sit with the orchestrator — no vault, no rotation, no short-lived tokens.
 - W2 Unsantitized RAG path**
File-server and vector-DB content flows into the LLM prompt unchecked — indirect prompt-injection vector.
 - W3 Ungated LLM → tool execution**
Model output triggers tool calls with no policy check, allowlist, or approval between inference and action.
 - W4 Unconstrained shell execution**
Arbitrary commands run on two hosts (Ubuntu terminal + CentOS host). No sandbox, allowlist, or restriction.
 - W5 Open email egress**
Agent-reachable SMTP relay with no DLP, recipient allowlist, or rate limits → data-exfiltration channel.
 - W6 RAG read/write loop**
The agent writes artifacts to the same file server it retrieves from → self-poisoning feedback loop.
 - W7 No logging or monitoring**
No SIEM, audit trail, or alerting anywhere in the design. Agent actions are unobservable.
 - W8 Flat privileged zone**
Inference, orchestration, tools, and data share one boundary — no east-west segmentation.
 - W9 No output filtering**
Responses return to the user unfiltered; the WAF inspects ingress only. No DLP or guardrails.
 - W10 No human-in-the-loop**
State-changing actions (shell, file writes, email) run fully autonomously with no approval gate.

 SENTINEL CYBER CONSULTING		Client	Design World
		Doc #	DW0004
Effective Date	07/05/26	Rev. #	Rev 1

b. **Target State Secure Architecture** - Redesigned system-level architecture: six segmented zones plus a governance plane, with each change mapped back to a weakness.

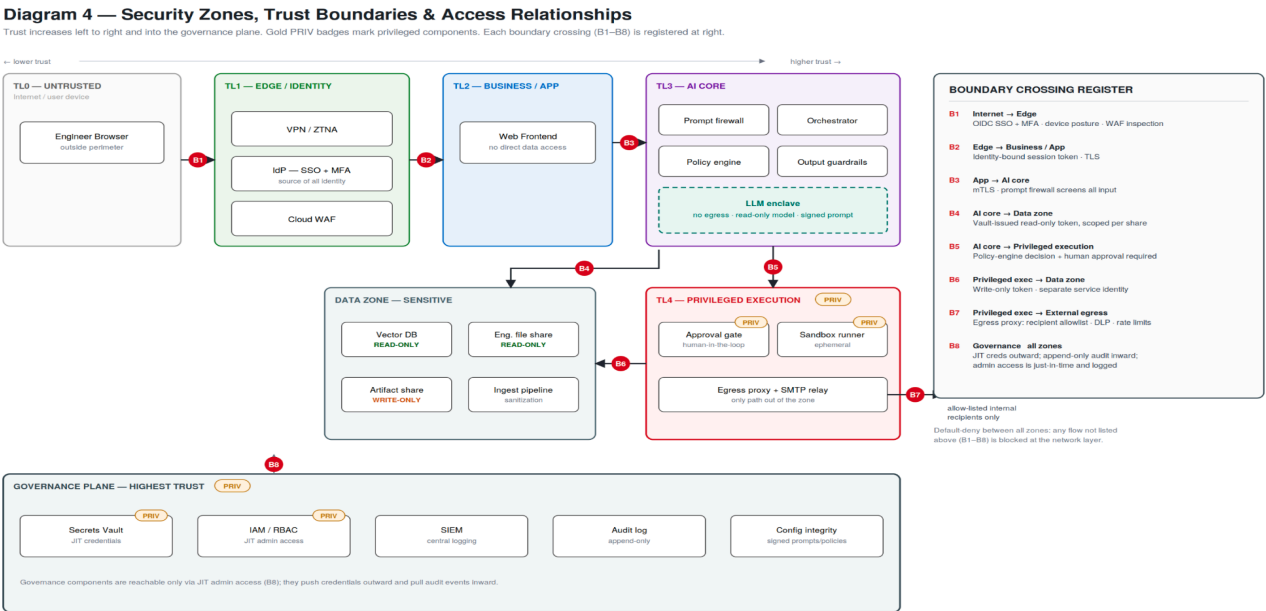


c. **Data Flow Diagram** - How data moves through the AI system - processes P1-P8, stores D1-D5, flows F1-F16, and four trust boundaries.

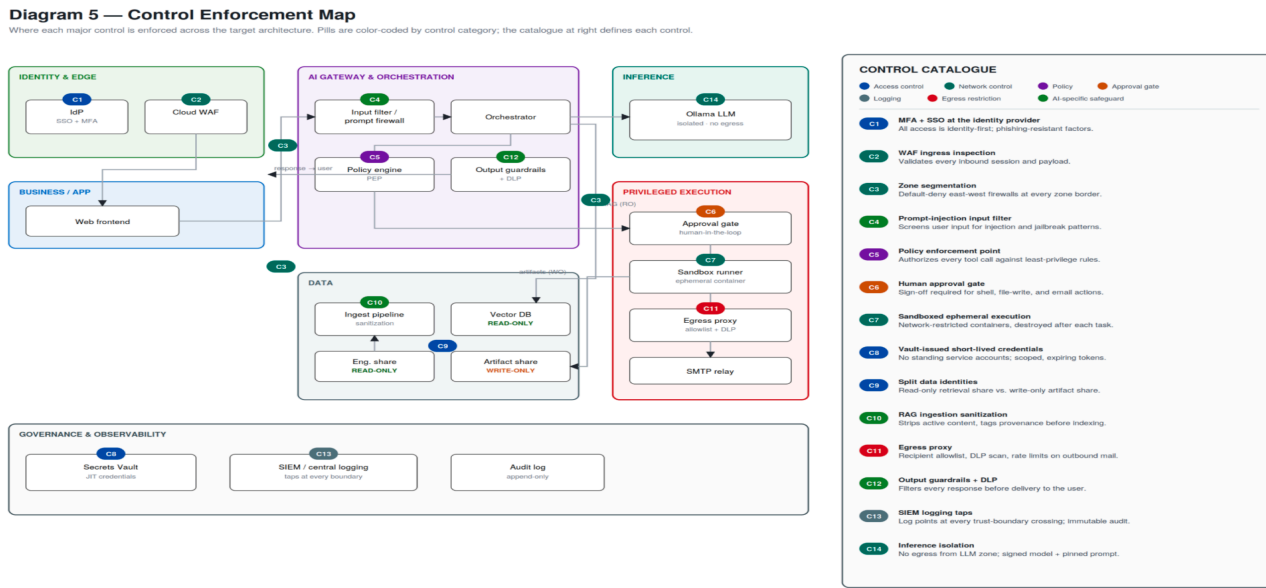


 SENTINEL CYBER CONSULTING		Secure Architecture Guide + Diagrams		Client	Design World
				Doc #	DW0004
Effective Date	07/05/26			Rev. #	Rev 1

d. **Security Zones, Trust Boundaries, & Access Relationships** - Trust levels
TL0-TL4, privileged components (PRIV), and a register of every allowed
boundary crossing (B1-B8)



e. **Control Enforcement Map** - Fourteen controls (C1-C14) placed where they are enforced - access, network, policy, approval, logging, egress, and AI safeguards



	Secure Architecture Guide + Diagrams	Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26		

4. Architecture Delta Summary

a. What the team changed

- i. Replaced the flat AI workflow with segmented security zones for:
 1. identity, business applications, AI orchestration, inference, data, and privileged execution.
- ii. Added a prompt firewall, policy enforcement point, and RAG ingestion sanitization.
 1. Output guardrails, a human approval gate, sandboxed tool execution, an egress proxy, and centralized SIEM logging.
 - a. Also an immutable audit log, and vault-issued short-lived credentials.
- iii. The team separated read-only engineering data from write-only artifact storage.

b. Why the team made these changes

- i. The team identified that unsanitized RAG content could reach the LLM.
 1. Found that the LLM could influence tool execution without strong authorization controls.
 - a. Identified standing service-account credentials as an unnecessary privilege risk.
- ii. We found that the current architecture lacked visible controls for shell execution, email egress, output filtering, and audit logging.
 1. These changes were made to reduce the risk of prompt injection, RAG poisoning, privilege misuse, lateral movement, and data exfiltration.

c. How the team reduced risk

- i. Applied default-deny network segmentation and revalidated trust at each boundary.
 1. Isolated the LLM from credentials and external egress so it can only propose actions, not execute them directly.
 2. Required calls to pass policy checks based on user identity, role, approved use case, data classification, and tool allowlists.
- ii. We required human approval for state-changing actions.
 1. Placed tool execution in ephemeral, network-restricted sandboxes.
- iii. The team routed email through an allowlisted egress proxy with DLP controls and rate limits.
 1. logging was added for prompts, retrieved sources, policy decisions, and tool actions.

d. New risks

	Secure Architecture Guide + Diagrams	Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26		

- i. Components including gateways, a policy engine, a secrets vault, an approval workflow, and a logging platform.
 - 1. These additions increase operational complexity and create new dependencies.
- ii. Potential policy misconfiguration, approval-service outages, or SIEM failures could block legitimate activity, reduce visibility, or create bottlenecks.

e. Tradeoffs

- i. Architecture hosted on Linode.
 - 1. Kept the local Ollama model.
- ii. No proprietary model fine-tuning or unrestricted external AI services.
- iii. Security would rely mainly on surrounding controls rather than model-level changes.
 - 1. Additional latency and administrative effort to remain within hosting, governance, and project-scope constraints.

5. Conclusions

This secure target-state architecture provides Design World with a more secure foundation for implementing its AI platform. The redesign addresses the major trust, governance, and enforcement gaps identified in the current architecture by making controls visible across all aspects of the system. The platform is now better aligned with Design World's security and governance requirements. These changes reduce the risk of prompt injection, unauthorized tool use, data exposure, and untraceable AI activity. Overall, the architecture supports Design World's business use cases while providing the evidence needed for future assurance activities and executive readiness decisions.

6. Approvals

Role	Printed Name	Signature	Date
Project Lead	Shivam Patel	<i>Shivam Patel</i>	07/05/26
Security Analyst	O.Kingsley Ero	<i>O.Kingsley Ero</i>	07/05/26
Security Analyst	Mohammad Ahmed	<i>Mohammad Ahmed</i>	07/05/26
Security Engineer	Joshua Remington	<i>Joshua Remington</i>	07/05/26

		Client	Design World
		Doc #	DW0004
		Rev. #	Rev 1
Effective Date	07/05/26	Secure Architecture Guide + Diagrams	

Security Engineer	Brian Che	<i>Brian Che</i>	07/05/26
Network Engineer	Mikailou Nikiema	<i>Mikailou Nikiema</i>	07/05/26
DW CEO			

		Secure Architecture Guide + Diagrams		Client	Design World
				Doc #	DW0004
Effective Date	07/05/26			Rev. #	Rev 1

Appendix

[Diagram 1 - Current State Architecture](#)

[Diagram 2 - Secure Target State Architecture](#)

[Diagram 3 - Data Flow Diagram](#)

[Diagram 4 - Security Zones, Trust Boundaries, and Access Relationships](#)

[Diagram 5 - Control Enforcement Map](#)